

Security+ 5.4 · Compliance

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 5.4 — Compliance (8:06)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Compliance: seguir a LEI + NORMA (PCI-DSS, HIPAA, GDPR, SOX/LGPD) do setor e região; reputational damage (perde cliente mesmo sem multa); monitoring (verificar, NÃO só na auditoria anual).

Highlights que a prova cobra

- Compliance: leis do setor + região (GDPR/PCI/HIPAA)
- Reputational damage costuma custar MAIS que a multa

Dicas de prova & Cenários Típicos

- 'protecting cardholder data'=PCI-DSS compliance

Cenário clássico de exame: 'processadora de cartão precisa seguir'=PCI-DSS.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 5.4 — Compliance)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Qual lei regula a proteção de dados pessoais na União Europeia?

- A)** HIPAA
- B)** GLBA
- C)** GDPR
- D)** SOX

2. HIPAA (Health Insurance Portability and Accountability Act) protege informações relacionadas a:

- A)** Dados financeiros
- B)** Dados educacionais
- C)** Informações de saúde protegidas (PHI)
- D)** Informações de defesa nacional

3. HIPAA, GLBA e GDPR protegem, respectivamente, dados de:

- A)** Saúde (US) / Financeiro (US) / Pessoais (UE)
- B)** Governo / Militar / Escolar
- C)** Cartão / Senha / Biometria
- D)** Nuvem / Rede / Endpoint

4. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: 'Compliance: leis do setor + região (GDPR/PCI/HIPAA)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Compliance: leis do setor + região (GDPR/PCI/HIPAA)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: 'Reputational damage costuma custar MAIS que a multa'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Reputational damage costuma custar MAIS que a multa...

6. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: "protecting cardholder data'=PCI-DSS compliance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'protecting cardholder data'=PCI-DSS compliance...

7. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: "processadora de cartão precisa seguir'=PCI-DSS.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'processadora de cartão precisa seguir'=PCI-DSS....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: 'Compliance: leis do setor + região (GDPR/PCI/HIPAA)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Compliance: leis do setor + região (GDPR/PCI/HIPAA)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: 'Reputational damage costuma custar MAIS que a multa'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Reputational damage costuma custar MAIS que a multa...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: 'protecting cardholder data'=PCI-DSS compliance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'protecting cardholder data'=PCI-DSS compliance...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) C — GDPR.

✓ **Por que está certa:** O GDPR (General Data Protection Regulation), Regulamento Geral de Proteção de Dados da União Europeia, é a lei que estabelece regras rigorosas sobre coleta, processamento, armazenamento e transferência de dados pessoais de indivíduos na UE. Entrou em vigor em 2018 e impõe obrigações extraterritoriais, afetando organizações em qualquer lugar que tratem dados de residentes europeus. A CompTIA Security+ inclui o GDPR como exemplo central de regulação de privacidade e proteção de dados.

✗ **Por que as outras estão erradas:**

- **HIPAA:** O HIPAA (Health Insurance Portability and Accountability Act) é uma lei dos Estados Unidos que regula a privacidade e segurança de informações de saúde protegidas (PHI). Aplica-se a entidades de saúde, planos de saúde e parceiros de negócios nos EUA, não à proteção geral de dados pessoais na União Europeia. Portanto, não é a legislação correta para o escopo europeu.
- **GLBA:** O GLBA (Gramm-Leach-Bliley Act) é uma lei norte-americana que exige que instituições financeiras expliquem como compartilham informações financeiras pessoais e protejam dados sensíveis. Seu foco é o setor financeiro dos EUA, não a proteção ampla de dados pessoais de cidadãos europeus. Não se aplica ao contexto da União Europeia.
- **SOX:** O SOX (Sarbanes-Oxley Act) é uma lei dos Estados Unidos que estabelece requisitos de auditoria e controles financeiros para empresas de capital aberto, visando prevenir fraudes contábeis. Embora tenha implicações de segurança da informação, não regula a proteção de dados pessoais na UE. É voltado à governança corporativa e relatórios financeiros, não à privacidade de dados europeus.

2) C — Informações de saúde protegidas (PHI).

✓ **Por que está certa:** A alternativa correta é 'Informações de saúde protegidas (PHI)'. O HIPAA (Health Insurance Portability and Accountability Act) é uma lei federal dos Estados Unidos, promulgada em 1996, que estabelece padrões nacionais para a proteção de informações de saúde individualmente identificáveis. O termo técnico central é PHI (Protected Health Information), que abrange qualquer informação sobre condição física ou mental, tratamento ou pagamento por cuidados de saúde que possa ser vinculada a um indivíduo específico. O HIPAA define regras rigorosas para o uso e divulgação dessas informações por entidades cobertas (planos de saúde, provedores de assistência médica e câmaras de compensação). A CompTIA Security+ exige que o candidato reconheça os principais regulamentos e suas áreas de aplicação, e o HIPAA é explicitamente associado à proteção de dados de saúde.

✗ **Por que as outras estão erradas:**

- **Dados financeiros:** Dados financeiros referem-se a informações como números de cartão de crédito, contas bancárias, histórico de crédito e transações financeiras. A proteção desses dados nos EUA é regida por leis como GLBA (Gramm-Leach-Bliley Act), PCI DSS (Payment Card Industry Data Security Standard) e SOX (Sarbanes-Oxley Act). Embora o HIPAA também exija a proteção de informações de pagamento quando vinculadas a cuidados de saúde, seu escopo principal não é a proteção genérica de dados financeiros. Portanto, esta alternativa está incorreta porque confunde o domínio de aplicação: HIPAA é específico para saúde, não para finanças.
- **Dados educacionais:** Dados educacionais são protegidos nos EUA pelo FERPA (Family Educational Rights and Privacy Act), que salvaguarda registros acadêmicos de estudantes. O HIPAA não se aplica a instituições de ensino enquanto tais, a menos que prestem serviços de saúde cobertos. A alternativa é incorreta porque atribui ao HIPAA uma responsabilidade que pertence ao FERPA, demonstrando falta de precisão regulatória.

- *Informações de defesa nacional*: Informações de defesa nacional envolvem dados classificados e sensíveis à segurança do Estado, protegidos por leis como o Espionage Act, regulamentos do Departamento de Defesa e diretrizes de classificação (ex.: Confidential, Secret, Top Secret). O HIPAA não tem jurisdição sobre informações de defesa; seu foco é exclusivamente a privacidade e segurança de informações de saúde. Esta opção é incorreta por deslocar completamente o escopo legal e técnico.

3) A — Saúde (US) / Financeiro (US) / Pessoais (UE).

✓ **Por que está certa:** HIPAA (Health Insurance Portability and Accountability Act) é uma lei dos Estados Unidos que protege dados de saúde, estabelecendo padrões para a privacidade e segurança de informações médicas. GLBA (Gramm-Leach-Bliley Act) é uma lei dos EUA que protege informações financeiras de consumidores, exigindo que instituições financeiras expliquem como compartilham dados e protejam a privacidade. GDPR (General Data Protection Regulation) é um regulamento da União Europeia que protege dados pessoais de cidadãos da UE, abrangendo qualquer informação relacionada a uma pessoa física identificada ou identificável. Portanto, a correspondência correta é: Saúde (US) / Financeiro (US) / Pessoais (UE). Esse conhecimento é essencial no domínio de Governança, Risco e Conformidade da certificação Security+ (SY0-701), objetivo 5.1.

✗ Por que as outras estão erradas:

- *Governo / Militar / Escolar*: HIPAA não se aplica exclusivamente a dados governamentais; GLBA não é específica para dados militares; e GDPR não regula apenas dados escolares. HIPAA regula informações de saúde em entidades cobertas, incluindo planos de saúde, provedores e câmaras de compensação. GLBA regula instituições financeiras. GDPR regula dados pessoais de residentes da UE, independentemente do setor. Essa alternativa confunde os escopos setoriais das leis com categorias genéricas de dados, não refletindo as áreas de proteção reais.
- *Cartão / Senha / Biometria*: Essa alternativa lista tipos de dados, não leis. HIPAA, GLBA e GDPR são normas legais que protegem categorias específicas de informações (saúde, financeiro, pessoais), e não 'cartão', 'senha' ou 'biometria'. Embora dados de cartão sejam protegidos pelo PCI DSS, senhas por políticas de segurança e biometria por leis de privacidade, essas não são as correspondências corretas para as três leis citadas. A questão pede a associação entre leis e os dados que elas protegem, não exemplos de dados sensíveis.
- *Nuvem / Rede / Endpoint*: Esses são domínios de infraestrutura de TI, não categorias de dados protegidos por leis. HIPAA não se limita a dados em nuvem; GLBA não regula apenas dados em rede; e GDPR não é específico para endpoints. As leis de privacidade e segurança focam no tipo de informação (saúde, financeira, pessoal) e não no local de armazenamento ou transmissão. Essa alternativa desvia o foco para aspectos técnicos de ambientes computacionais, ignorando o escopo legal e regulatório.

4) A — Implementar a solução correspondente: Compliance: leis do setor + região (GDPR/PCI/HIPAA)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): Compliance: leis do setor + região (GDPR/PCI/HIPAA).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: Reputational damage costuma custar MAIS que a multa....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): Reputational damage costuma custar MAIS que a multa.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: 'protecting cardholder data'=PCI-DSS compliance....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): 'protecting cardholder data'=PCI-DSS compliance.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: 'processadora de cartão precisa seguir'=PCI-DSS.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): 'processadora de cartão precisa seguir'=PCI-DSS..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: Compliance: leis do setor + região (GDPR/PCI/HIPAA)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): Compliance: leis do setor + região (GDPR/PCI/HIPAA).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: Reputational damage costuma custar MAIS que a multa....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): Reputational damage costuma custar MAIS que a multa.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: 'protecting cardholder data'=PCI-DSS compliance....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): 'protecting cardholder data'=PCI-DSS compliance.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

